Backend Engineering Notes

Chapter 1: HTTP and REST

REST APIs use HTTP verbs such as GET, POST, PUT and DELETE to operate on resources. Status codes communicate the outcome of a request: 2xx means success, 4xx means a client error and 5xx means a server error. Idempotent methods like PUT and DELETE can be safely retried without changing the result beyond the first application.

Chapter 2: Authentication with JWT

A JSON Web Token (JWT) is a compact, URL-safe token made of three parts: a header, a payload and a signature. The server signs the token with a secret key, so any tampering with the payload invalidates the signature. JWTs are stateless: the server does not need to store sessions because the token itself carries the user identity.

Access tokens should be short-lived, typically 15 minutes, to limit the damage if one is stolen. Refresh tokens are long-lived credentials used only to obtain new access tokens. Refresh tokens should be stored in httpOnly cookies and rotated on every use, so a reused refresh token signals theft and the whole token family can be revoked.

Chapter 3: Databases

PostgreSQL is a relational database that supports transactions, foreign keys and rich indexing. The pgvector extension adds a vector column type and operators such as cosine distance, enabling semantic similarity search directly in SQL. HNSW indexes provide fast approximate nearest neighbour search over embeddings.